

TP24 : Portswigger

1) Problématique.....	1
2) Exercices.....	1
3) Conclusion.....	5

1) Problématique

Nous souhaitons apprendre la façon dont on utilise des outils professionnels utilisés par des experts de la cybersécurité pour comprendre l'intérêt de l'utilisation de ces outils. Dans notre cas nous allons utiliser le logiciel Burp Suite qui nous permettra d'agir comme un proxy d'interception, qui se positionne entre le navigateur de l'utilisateur et le serveur web et qui nous permet d'inspecter, d'intercepter et de manipuler l'intégralité du trafic HTTP et HTTPS en temps réel.

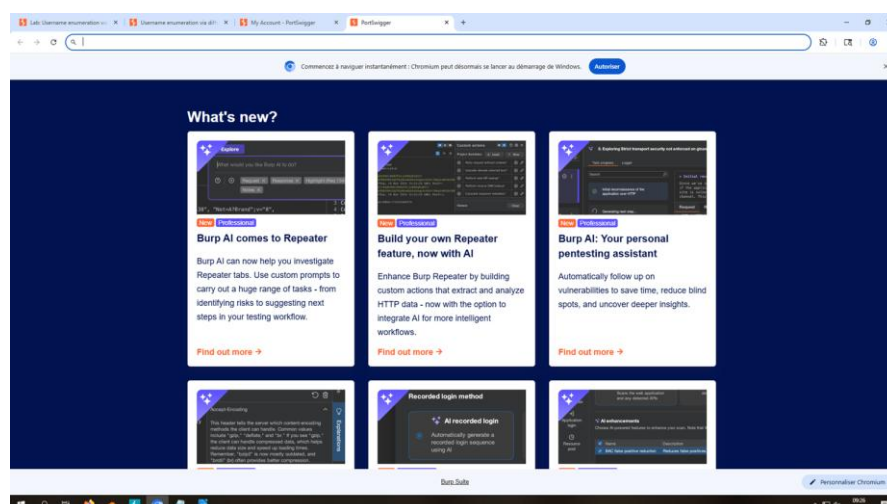
2) Exercices

Pour pouvoir démarrer il faut installer Burp suite, on peut le faire avec l'adresse suivante :

<https://portswigger.net/burp/communitydownload>

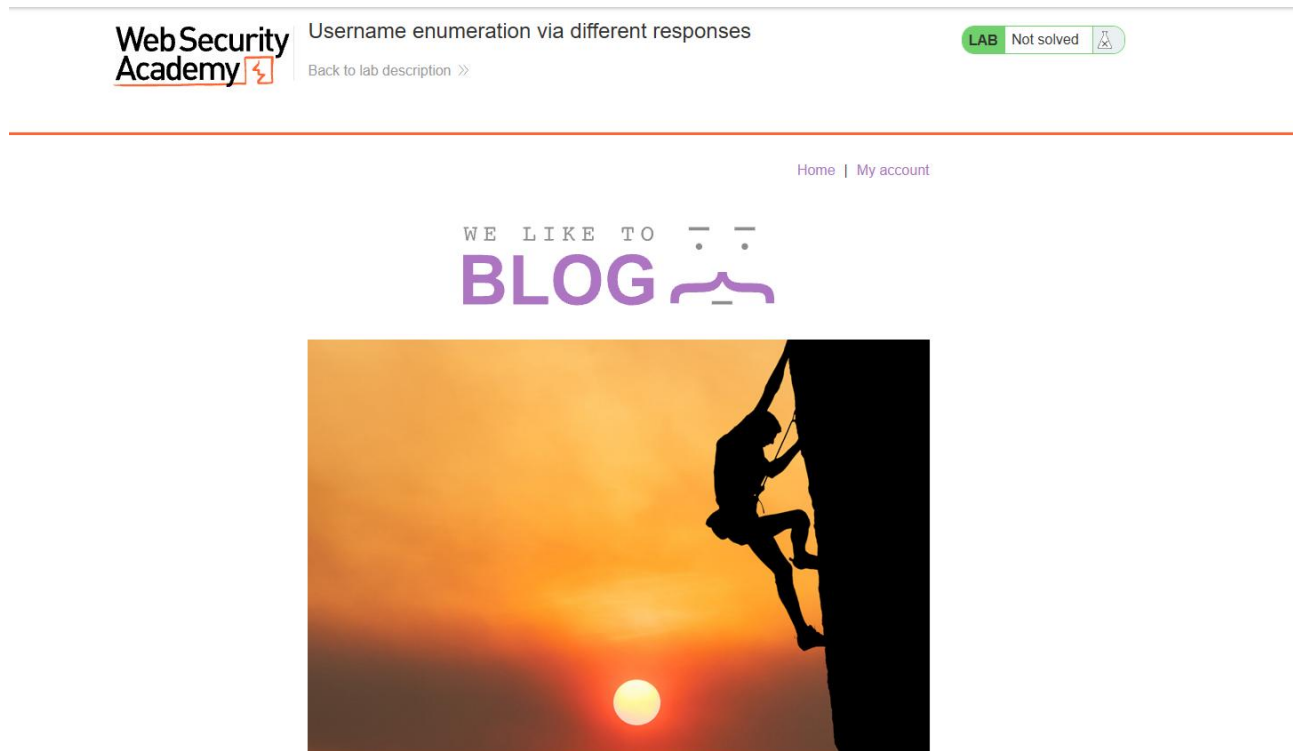
Ensuite nous devons nous créer un compte sur portswigger, pour pouvoir ensuite faire l'exercice "**Username enumeration via different responses**".

Lorsque Burp Suite est installé, nous pouvons aller sur l'onglet Proxy et ouvrir le navigateur du logiciel :



Ensuite on copie colle ce lien dans le navigateur, on doit avant ça se connecter au compte que l'on a créé, le lien est le suivant : <https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses>

On accède au Lab et on tombe sur cette page :



Commençons par accéder à « My account ».

On tombe sur la page de connexion, ensuite on remplit avec un faux username et un faux mot de passe.

Username

summer123456

Password

.....

Log in

On clique sur Log in, le username sera invalide mais c'est pas grave car maintenant on a ce qu'il nous faut.

Dans Burp suite, nous allons accéder au HTTP History and trouver la méthode POST avec l'endpoint /login :

#	Host	Met...	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener por
569	https://phingest.staging.por...	POST	/s/?ip=0&_=1778139059581&ver...	✓		200	308	JSON				✓	54.78.191.54		09:30:59 7 ...	8080
570	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json	✓		200	370	JSON				✓	142.251.208.238		09:31:04 7 ...	8080
571	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json	✓		200	370	JSON				✓	142.251.208.238		09:31:04 7 ...	8080
572	https://phingest.staging.por...	POST	/s/?ip=0&_=1778139066276&ver...	✓		200	308	JSON				✓	54.78.191.54		09:31:06 7 ...	8080
574	https://phingest.staging.por...	POST	/s/?ip=0&_=1778139092277&ver...	✓		200	308	JSON				✓	54.78.191.54		09:31:32 7 ...	8080
579	https://0a460030036764328...	POST	/login	✓		200	3352	HTML		Username enumerati...		✓	34.246.129.62		09:32:30 7 ...	8080

Lorsqu'on a trouvé la méthode, on fait clique droit dessus et on clique sur « Send to Intruder ».

On accède ensuite à l'onglet Intruder et on clique sur clear :

⚡ Burp Project Intruder Repeater View Help

Burp Suite Community Edition v2026.3.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions

1 2 × +

?

Sniper attack

Start attack

Target

https://0a4600300367643280c0bcbe004d0028.web-security-academy.net

☒ Update Host header to match target

Positions

Add 5

Clear 5

Auto 5

1 POST /login HTTP/2

2 Host: 0a4600300367643280c0bcbe004d0028.web-security-academy.net

3 Cookie: session=o8MGwTrNLCQz8qhQyh75okncrOdxImN3

4 Content-Length: 37

5 Cache-Control: max-age=0

6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"

7 Sec-Ch-Ua-Mobile: ?0

8 Sec-Ch-Ua-Platform: "Windows"

9 Accept-Language: fr-FR,fr;q=0.9

10 Origin: https://0a4600300367643280c0bcbe004d0028.web-security-academy.net

11 Content-Type: application/x-www-form-urlencoded

12 Upgrade-Insecure-Requests: 1

13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

14 Accept:

15 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

16 Sec-Fetch-Site: same-origin

17 Sec-Fetch-Mode: navigate

18 Sec-Fetch-User: ?1

19 Sec-Fetch-Dest: document

20 Referer: https://0a4600300367643280c0bcbe004d0028.web-security-academy.net/login

21 Accept-Encoding: gzip, deflate, br

22 Priority: u=0, i

23 username=summer123456&password=123456

On laisse le mode d'attaque par défaut : Sniper attack.

On la valeur du paramètre username (summer123456) et on l'ajoute en tant que marqueur en cliquant sur Add.

Dans la page de portswigger on ouvre la page des usernames :

- Candidate usernames

On copie colle la liste en cliquant sur Paste dans la section Payloads.



Action	Candidate usernames
Paste	carlos
Load...	root
Remove	admin
Clear	test
Deduplicate	guest
	info
	adm

Ensuite on clique sur 

Une page s'ouvre, l'attaque est faite, on filtre par longueur, on tombe sur une valeur différente des autres :

Request	Payload	Status code	Response received	Error	Timeout	Length	...
92	athena	200	99			3354	

Essayons de nous connecter avec ce username. On tombe sur :

Incorrect password

ce qui signifie que l'username existe bien.

On retourne dans l'onglet positions et on modifie le username :

```
username=$athena&password=123456
```

On clique sur clear, puis on ajoute le password en tant que marqueur.

On va faire pareil mais avec

- Candidate passwords

Dans l'onglet Payloads on clique sur clear puis on paste.

On lance l'attaque, on filtre par longueur, on tombe sur ce mot de passe avec le status code 302 et une longueur plus petite que les autres résultats.

Request	Payload	Status code	Response received	Error	Timeout	Length ^
2	password	302	57			188

Le mot de passe du compte athena est donc « password »

On a réussi !

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: athena

Your email is: athena@normal-user.net

Email

Update email

3) Conclusion

En conclusion, j'ai réussi à utiliser le logiciel Burp Suite pour trouver un identifiant et un mot de passe, ce qui montre la puissance du logiciel et l'utilité de celui-ci.